

servers connecting to a database server. One authentication method, particularly the one provided by the database service, should be used. When we don't use operating system-based authentication, we automatically keep unauthorised users away, making the access control job easier. As for roles, a minimum set of roles should be created to avoid future confusion, and the roles should be application-specific, rather than purpose-specific. This helps in keeping track of which user did what, in terms of accessing the resources. Disabling unwanted database features and services is a good idea too.

In terms of data integrity, using SSL or TLS encryption is useful, especially to avoid packet sniffing of the data flowing between the requesting server and the database server. As for data encryption, there are built-in features available for the database server, whereby the encryption can be achieved for the entire database, or at a granular level such as a table or schema. This helps to achieve data security without compromising on server performance. In modern architectures, a dedicated firewall for database servers or farms is very common, allowing only the database port to be accessible from only a set of IP addresses. In case of mission critical data handling, IPsec security along with NAT (network address translation) is encouraged. Firms that store massive amounts of business critical data for their customers can also think of deploying

honey pots, whereby hackers trying to invade the network are lured to a fake database server, thus keeping them away from the real critical data.

A summary

Database hacking is highly favoured by hackers because of the rewards. It is achieved by exploiting inherent vulnerabilities. It is important for network administrators to properly configure firewalls, frame database policies, and follow best practices for the roles and rules in order to protect corporate data from prying eyes. It is important to note that the legacy method of protecting database servers at the operating system level is not sufficient today; rather, the careful design and deployment of intrusion detection and removal components is required. 

By: Prashant Phatak

The author has over 18 years of experience in the field of IT hardware, networking, Web technologies and IT security. Prashant is MCSE and MCDBA certified and is also a F5 load balancer expert. In the IT security world, he is an ethical hacker and a Net-forensic specialist. Prashant runs his own firm named Valency Networks in India (www.valencynetworks.com) providing consultancy in IT security design, security audit, infrastructure technology and business process management. He can be reached at prashant@valencynetworks.com

www.linuxforu.com

Managing IT is simpler, and more cost effective using Open Source

More and more
IT Managers are
adopting Open Source.
What about You?

Develop software —
cheaper, faster and better
with Open Source

Read **LINUX For You:**
Asia's Leading Open Source Magazine

